

ZAP Scanning Report

Site: <https://dealerstaging2.bullbbq.com>

Generated on Sat, 26 Aug 2023 21:03:59

ZAP Version: 2.13.0

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	5
Informational	4

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	1
CSP: script-src unsafe-inline	Medium	1
CSP: style-src unsafe-inline	Medium	1
Cookie No HttpOnly Flag	Low	1
Cookie without SameSite Attribute	Low	1
Strict-Transport-Security Header Not Set	Low	1
Timestamp Disclosure - Unix	Low	1
X-Content-Type-Options Header Missing	Low	1
Loosely Scoped Cookie	Informational	1
Modern Web Application	Informational	1
Session Management Response Identified	Informational	3
User Agent Fuzzer	Informational	12

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	

Evidence	frame-ancestors 'self'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src, worker-src, prefetch-src, form-action The directive(s): form-action are among the directives that do not fallback to default-src, missing/excluding them is the same as allowing anything.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	frame-ancestors 'self'
Other Info	script-src includes unsafe-inline.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website

	owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	frame-ancestors 'self'
Other Info	style-src includes unsafe-inline.
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	http://www.w3.org/TR/CSP2/ http://www.w3.org/TR/CSP/ http://caniuse.com/#search=content+security+policy http://content-security-policy.com/ https://github.com/shapesecurity/salvation https://developers.google.com/web/fundamentals/security/csp#policy_applies_to_a_wide_variety_of_resources
CWE Id	693
WASC Id	15
Plugin Id	10055

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	Set-Cookie: bm_sv
Other Info	
Instances	1
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	Set-Cookie: bm_sv

Other Info	
Instances	1
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://tools.ietf.org/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html https://owasp.org/www-community/Security-Headers http://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security http://caniuse.com/stricttransportsecurity http://tools.ietf.org/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server - Unix
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	1693092022
Other Info	1693092022, which evaluates to: 2023-08-26 20:20:22
Instances	1
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	http://projects.webappsec.org/w/page/13246936/Information%20Leakage
CWE Id	200
WASC Id	13
Plugin Id	10096

--	--

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	1
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	http://msdn.microsoft.com/en-us/library/ie/gg622941%28v=vs.85%29.aspx https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Loosely Scoped Cookie
Description	Cookies can be scoped by domain or path. This check is only concerned with domain scope. The domain attribute of a cookie determines which domains can access it. For example, a cookie can be scoped strictly to a domain like www.nottrusted.com, or loosely scoped to a parent domain e.g. nottrusted.com. In the latter case, any subdomain of nottrusted.com can access the cookie. Loosely scoped cookies are common in mega-application like live.com. Cookies set from a subdomain like app.foo.bar are transmitted only to that domain by default. Cookies scoped to a parent-level domain may be transmitted to the parent, or any subdomain of the parent.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	
Other Info	The origin domain used for comparison was: dealerstaging2.bullbbq.com bm_sv=C6F08816B33C022812A6402962C045A2~YAAQVRwoyP /aiPSJAQAAtQgmNBSfslbWZGjuXH1mX8DBYK0X8+JsKgtF3AONZ7DLS8uOZaEx6vtxhx3iZth /DLslmjAc1XWj/xdCZIHWCEnOi3x7tbHfLMRzpqx7WkOt8V656njhIAmu85cf7E4Ph4BRxfiDtq+0y /wODRULLkKFyARg7q/KcaDoboptocpwZTVLoCTQs8fdyMq0g03JmiWU7LyoNklO7Lb6NzsU=-
Instances	1
Solution	Always scope cookies to a FQDN (Fully Qualified Domain Name).
Reference	https://tools.ietf.org/html/rfc6265#section-4.1 https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/Session_Management_Testing/02-Testing_for_Cookies_Attributes.html http://code.google.com/p/browsersec/wiki/Part2#Same-origin_policy_for_cookies
CWE Id	565
WASC Id	15
Plugin Id	90033

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	<script> window.applicationStartTime = Date.now(); </script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other of header tokens that can be used in the Header Based Session Management Method. If the request has a Session Management Method set to "Auto-Detect" then this rule will change the session management tokens identified.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	C6F08816B33C022812A6402962C045A2~YAAQVRwoyP /aiPSJAQAAtQgmNBSfslbWZGjuXH1mX8DByK0X8+JsKgtF3AONZ7DLS8uOZaEx6vtxhx3iZth /DLslmjAc1XWj/xdCZIHWCEnOi3x7tbHfLMRzpqx7WkOt8V656njhIAmu85cf7E4Ph4BRxfiDtq+0j /wODRULLkKFyARg7q/KcaDoboptocpwZTVLoCTQs8fdyMq0g03JmiWU7LyoNklO7Lb6NzsU=-
Other Info	cookie:bm_sv cookie:SSPOperationId_6706030
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	C6F08816B33C022812A6402962C045A2~YAAQVRwoyP /aiPSJAQAAtQgmNBSfslbWZGjuXH1mX8DByK0X8+JsKgtF3AONZ7DLS8uOZaEx6vtxhx3iZth /DLslmjAc1XWj/xdCZIHWCEnOi3x7tbHfLMRzpqx7WkOt8V656njhIAmu85cf7E4Ph4BRxfiDtq+0j /wODRULLkKFyARg7q/KcaDoboptocpwZTVLoCTQs8fdyMq0g03JmiWU7LyoNklO7Lb6NzsU=-
Other Info	cookie:bm_sv
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	
Evidence	3a21674a-6131-4a15-9305-639a074b2fb6
Other Info	header:X-N-OperationId
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id

CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.124 Safari/537.36
Evidence	
Other Info	

URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:93.0) Gecko/20100101 Firefox/91.0
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (compatible; Yahoo! Slurp; http://help.yahoo.com/help/us/ysearch/slurp)
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (iPhone; CPU iPhone OS 8_0_2 like Mac OS X) AppleWebKit/600.1.4 (KHTML, like Gecko) Version/8.0 Mobile/12A366 Safari/600.1.4
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	Mozilla/5.0 (iPhone; U; CPU iPhone OS 3_0 like Mac OS X; en-us) AppleWebKit/528.18 (KHTML, like Gecko) Version/4.0 Mobile/7A341 Safari/528.16
Evidence	
Other Info	
URL	https://dealerstaging2.bullbbq.com/38-Double-Door-Pantry-Insert
Method	GET
Attack	msnbot/1.1 (+http://search.msn.com/msnbot.htm)
Evidence	
Other Info	
Instances	12
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104

